



UNIVERSIDAD PRIVADA DE TACNA

FACULTAD DE INGENIERÍA

Escuela Profesional de Ingeniería de Sistemas

**FinanceFlow: Plataforma Web de Gestión
Financiera e Inteligencia Artificial para el Control
de Gastos Personales**

Curso: Construcción de Software I

Docente: Mag. Ricardo Eduardo Valcárcel Alvarado

Integrantes:

Sebastian Arce Bracamonte

(2019062886)

Brant Antony Chata Choque

(2020067577)

Tacna – Perú

2026

Plan de Riesgos - FinanceFlow

Este documento detalla los riesgos reales identificados en la arquitectura, desarrollo, seguridad y despliegue del sistema FinanceFlow, estableciendo planes de mitigación y contingencia para cada uno.

1. Identificación y Evaluación de Riesgos

ID Riesgo	Descripción del Riesgo	Probabilidad	Impacto	Severidad (PxI)	Plan de Mitigación (Preventivo)	Plan de Contingencia (Correctivo)
RS G-001	Indisponibilidad del backend de IA (FastAPI): El servidor en Render entra en suspensión o falla, impidiendo la extracción por OCR.	4	3	12	Implementar pings periódicos y monitoreo en Render.	El frontend detecta la caída de red en [useImageToMovimiento.js](file:///c:/Users/windows11/Documents/GitHub/Sistema%20de%20balance/frontend/src/hooks/useImageToMovimiento.js) y muestra una alerta amigable permitiendo al usuario ingresar los datos de forma manual.
RS G-002	Fallas en la extracción OCR: Imágenes borrosas o formatos de voucher no estándar impiden detectar el monto exacto.	3	3	9	Pre-procesar la imagen con OpenCV (escala de grises, filtro Gaussian o, umbral de Otsu) en [main.py](file:///c:/Users/windows11/Documents/GitHub/Sistema%20de%20balance/ml_backend/main.py) antes de	Configurar el backend para devolver un monto de 0 con un mensaje de advertencia para que el usuario complete o corrija la información en el formulario.

					pasar a Tesseract.	
RS G-003	Vulnerabilidad de acceso/edición cruzada de transacciones: El endpoint de inactivación PATCH no valida que el userId de la transacción coincida con el del token.	3	5	15	Corregir la consulta en el controlador [movimientos.controler.js](file:///c:/Users/windows/11/Documents/GitHub/Sistema%20de%20balance/backend/controllers/movimientos.controller.js) buscando el registro mediante _id y userId conjuntamente.	Realizar auditorías de código (Code Reviews) antes de cada merge a main y monitorear los logs de transacciones anómalas.
RS G-004	Latencia inicial por suspensión en Render: Los servidores gratuitos de Render suspenden el proceso tras 15 minutos de inactividad, tardando hasta 50 segundos en reaccionar.	4	2	8	Integrar UptimeRobot para realizar peticiones GET a los endpoints /health cada 5 minutos.	Mostrar un spinner de carga descriptivo en el frontend para evitar que el usuario piense que la aplicación se congeló.

RS G-0 05	Ataques de fuerza bruta en inicio de sesión: Ausencia de control de tasa de solicitudes en endpoints críticos (/login, /forgot-password).	3	4	12	Implementar el middleware express-rate-limit en la configuración inicial del backend Express.	Monitorear e inhabilitar temporalmente cuentas con bloqueos repetidos y alertar al administrador del servidor.
-----------------	--	---	---	----	---	--

2. Niveles de Severidad y Acciones

- Severidad Alta (12-25): Requiere mitigación inmediata en la base de código. Se prioriza la corrección de la verificación de pertenencia de movimientos (RSG-003).
- Severidad Media (6-11): Requiere manejo en tiempo de ejecución (ej. alertas de OCR fallido en RSG-002).
- Severidad Baja (1-5): Riesgos aceptados o mitigados mediante automatizaciones simples de infraestructura (UptimeRobot en RSG-004).